智慧醫療與科技發展　Smart Healthcare & Technology Development

13

醫療 AI 法規、倫理與資料治理

Regulation, Ethics & Data Governance of Medical AI

第 13 週｜評估、治理與落地　Unit 4
SaMD 判定 → 風險分級 → 各國監管 → 可解釋與模型卡 → 個資與去識別化 → 產品判定演練

謝楠楨 講座教授 ・ 2026 ・ 雙語版（English terms ＋ 中文講解）

本週地圖 This Week

本週六個部分

W12 問「它有沒有用」，本週問「它合不合法、能不能安全地用」

01

SaMD 判定

SaMD

什麼 AI 軟體算醫療器材

02

風險分級

Risk Classes

IMDRF 、台灣、歐盟分級

03

各國監管

Regulation

TFDA 、 FDA PCCP 、歐盟 AI 法案

04

倫理與透明

Ethics & Transparency

可解釋性、告知、模型卡

05

資料治理

Data Governance

個資法、健保資料、去識別化

06

案例與演練

Cases

DeepMind 案、產品判定

教學重點｜法規不是開發完才要面對的關卡；越早判定產品屬性，越能少走冤枉路。

學習目標 Learning Objectives

本週結束時，你能夠……

每一項目標都對應課程三項核心能力；期中、期末個案分析即依此命題

1	依預期用途判斷一項 AI 軟體是否為醫療器材	C2 技術應用
2	用 IMDRF 矩陣、台灣三級與歐盟 Rule 11 判斷風險等級	C2 技術應用
3	比較台美歐監管重點，以及台灣 AI 基本法與衛福部指引	C1 趨勢洞察
4	運用模型卡、去識別化與隱私強化技術設計資料治理	C3 實證評估

對應評量｜期末 Q2 （法規倫理）

課程脈絡 Where we are

承上

W12 它有沒有用

本週

它合不合法、能不能安全地用

啟下

W14 值不值得、推不推得動

教學重點｜本週結束時， W12 的「七份證據」會擴充成一張完整的 AI 採購檢核表。

開場 Opening

北城區域醫院資訊室，同一週收到三個 AI 提案

哪些要有 TFDA 許可證？哪些不用？不用的就可以不管嗎？

A　肺結節偵測 AI

在胸部 X 光上標出可疑結節，供放射科醫師參考

B　病床調度預測

預測明日各病房出院數，協助排床與人力調度

C　樂齡跌倒 App

長者拍一段走路影片， App 告知跌倒風險並給建議

同時，一位病人家屬來信：「我爸的病歷，是不是被你們拿去訓練 AI 了？我能拒絕嗎？」

教學重點｜本週學完，你要能回答這四個問題——最後的演練就是這三個產品的判定。

01

PART 1

什麼 AI 軟體算醫療器材 Software as a Medical Device

看的不是技術，而是「預期用途」

SaMD 的定義與三種軟體類型
判定流程：同一個技術，不同宣稱，結果不同

Part 1 ｜定義

醫療器材軟體的三種樣態

依國際醫療器材法規管理論壇（IMDRF）定義： SaMD 是「本身即具醫療用途、不屬於硬體一部分」的軟體

獨立醫療器材軟體 SaMD

軟體本身就是醫材，可在一般電腦或手機上執行

例子
影像 AI 輔助偵測、心電圖 AI 判讀

醫材

醫材內含軟體 SiMD

控制或驅動醫療器材硬體的軟體

例子
呼吸器、輸液幫浦的控制程式

醫材

非醫療器材軟體 Non-device

不具醫療用途的健康或管理軟體

例子
掛號、排班、計步 App 、病床調度

非醫材

台灣法源： 《醫療器材管理法》（2021-05-01 施行）； TFDA 《醫療器材軟體認定參考指引》說明哪些軟體屬於醫材。

教學重點｜ AI 只是技術；是不是醫材，要看它「宣稱要做什麼」——診斷、治療、預防疾病，就是醫療用途。

Part 1 ｜判定流程

四個問題，判斷 AI 軟體是不是醫療器材

簡化流程，實際以 TFDA 認定指引與個案諮詢為準

Q1	**是否用於診斷、治療、緩解、預防疾病，或影響人體結構與功能?**	→ 否 → 非醫材（行政、一般健康）
Q2	**是否分析醫學影像、生理訊號或檢驗訊號?**	→ 是 → 通常屬醫材
Q3	**對象是病人或民眾自行使用，而非醫事人員?**	→ 是 → 風險較高，通常屬醫材
Q4	**醫事人員能否獨立檢視依據，不主要依賴它做決定?**	→ 否 → 屬醫材（ W8 FDA 條件④）

教學重點｜台灣實務上，多數會產生診斷或治療建議的 AI 都會被認定為醫材；有疑義時可向 TFDA 申請認定。

Part 1 ｜關鍵觀念

同一個技術，宣稱不同，身分就不同

以手機鏡頭量測心率的 App 為例（教學示意）

宣稱越強 → 身分與風險越高

「記錄運動時的心率變化」
一般健康與運動管理

非醫材

「提醒你心率偏高，可留意休息」
一般健康提醒，未指向特定疾病

多屬非醫材

「偵測心房顫動，建議就醫」
指向特定疾病的偵測

醫材

「判定心房顫動，可依結果調整抗凝血藥」
直接影響治療決策

醫材，風險更高

同一個「手機鏡頭量心率」技術（教學示意）；判斷依據含產品說明、廣告文案、 App 商店描述、操作畫面文字

教學重點｜新創常見的風險：技術相同，但行銷文案一寫「偵測疾病」，產品就變成未經許可的醫療器材。

02

PART 2

風險分級 Risk Classification

管多嚴，取決於「出錯時會傷害到什麼程度」

IMDRF SaMD 風險矩陣
台灣三級制與歐盟 MDR 第 11 條規則

Part 2 | IMDRF 矩陣

IMDRF SaMD 風險矩陣：情境嚴重度 × 資訊重要性

IMDRF （2014） SaMD 風險分類框架； IV 風險最高

情境 ＼ 資訊重要性	治療或診斷 Treat / Diagnose	驅動臨床處置 Drive management	提供臨床參考 Inform management
危急 Critical	IV	III	II
嚴重 Serious	III	II	I
非嚴重 Non-serious	II	I	I

例：心衰竭惡化預警（嚴重 × 驅動處置）→ II；急性中風大血管阻塞偵測並通知（危急 × 驅動處置）→ III

教學重點｜同一套演算法，用在「危急情境」或「直接下診斷」時，風險等級就往上跳。

台灣三級制與歐盟 MDR 第 11 條規則

AI 醫材多數落在中等風險，但歐盟對軟體的分級普遍較高

台灣《醫療器材管理法》

- **第一級：**低風險，多數免查驗登記
- **第二級：**中風險，需查驗登記；多數 AI 醫材在此
- **第三級：**高風險，需較完整臨床證據
- **累計：** TFDA 已協助逾 300 件 AI 醫材取得許可證（2026 年 6 月）

歐盟 MDR 第 11 條規則

- **基本：**提供診斷或治療決策資訊的軟體至少為 IIa 級
- **IIb 級：**可能導致健康嚴重惡化或需手術介入
- **III 級：**可能導致死亡或不可逆的健康惡化
- **結果：**許多在他國屬低風險的軟體，在歐盟需公告機構審查

資料來源：醫療器材管理法； EU MDR (Regulation (EU) 2017/745) Annex VIII Rule 11 ； 蕃新聞（2026-06-30）引食藥署智慧醫材專案辦公室。

教學重點｜規劃國際上市時，要用「最嚴格的市場」來設計證據，避免同一產品重做多次臨床評估。

03

PART 3

各國監管重點 Regulatory Landscape

AI 會學習、會更新——監管從「一次審查」走向「全生命週期」

台灣 TFDA 指引與送件重點；美國 FDA PCCP 與 GMLP
歐盟 AI 法案的高風險義務；台灣 AI 基本法與衛福部指引

Part 3 ｜核心挑戰

為什麼 AI 醫材特別難管：模型會變

傳統醫材上市後很少改變； AI 模型需要隨資料與場域更新（ W8 資料集偏移）

設計開發 → 上市前審查 → 上市使用 → 監測偏移 → 模型更新

鎖定模型 Locked

- 上市後演算法固定不變
- 審查簡單，但效能可能逐漸變差
- 目前多數核准 AI 醫材屬此類

可調適模型 Adaptive

- 上市後依新資料持續學習或更新
- 能維持效能，但每次改版都要審查?
- PCCP 就是為了解決這個問題

教學重點｜監管的新思維是「全產品生命週期（ TPLC ）」：審查的不只是模型，而是廠商管理模型的能力。

TFDA： AI 醫材查驗登記要準備什麼

依《人工智慧／機器學習技術之醫療器材軟體查驗登記技術指引》（2020）整理重點

☐ 預期用途
適應症、使用者、情境、禁忌

W12： 適用範圍

☐ 演算法說明
架構、輸入輸出、決策閾值

本週新增

☐ 資料集
來源、期間、族群、標註者資格

W12： 資料來源

☐ 資料切分
訓練、調校、測試彼此獨立

W12： 資料洩漏

☐ 效能評估
敏感度、特異度、 AUROC ＋區間；次族群

W12： 完整指標

☐ 臨床評估
以臨床資料證明安全與效能

W12： 外部驗證

☐ 網路安全
資料傳輸、存取控制、弱點管理

本週新增

七項中五項
W12 已學過
好的研究設計＝好的送件資料

教學重點｜W12 的評讀能力和 TFDA 送件要求高度重疊——好的研究設計，就是好的查驗登記資料。

FDA： 預先核准的修改計畫（ PCCP ）與良好機器學習實務

PCCP： 正式指引，現行版 2025 年 8 月｜ AI 醫材生命週期指引：草案（2025 年 1 月），至 2026-10 仍未定稿

PCCP 三要素

1	**修改描述**	預計做哪些修改，例如以新資料再訓練
2	**修改程序**	如何開發、驗證、實施這些修改
3	**影響評估**	修改的效益與風險，以及如何控管

GMLP 十項原則（節錄）

- 跨領域專業參與整個生命週期
- 訓練與測試資料彼此獨立
- 資料能代表預期使用族群
- 重視「人機團隊」的整體表現
- 提供使用者清楚的必要資訊
- 上市後監測效能並管理再訓練風險

資料來源： FDA PCCP 正式指引（現行版 2025-08-18； 2024-12 首次發布）； 生命週期指引草案（2025-01）； GMLP （2021）。查核 2026-10-17。

教學重點｜ PCCP 的精神：把「未來要怎麼改」先講清楚、先審查，之後照計畫改就不必每次重新申請。

歐盟：醫療 AI 同時受 MDR 與 AI 法案管理

屬於醫材的 AI 被列為「高風險 AI 系統」；醫材相關義務原定 2027-08-02，2026 年數位綜合法案暫定協議延至 2028-08-02

廠商要做到		醫院（部署者）要做到
全生命週期辨識與降低風險	**風險管理**	導入前做風險評估
訓練資料具代表性、檢查偏誤	**資料治理**	要求廠商說明資料來源
自動記錄運作日誌，可追溯	**技術文件與紀錄**	**保存 AI 輸出與使用紀錄**
使用說明揭露能力與限制	**透明度**	確認仿單與模型卡
設計可讓人理解、介入與停止	**人類監督**	**流程中保留人工判斷**
宣告效能並抵禦攻擊	**準確、穩健、資安**	上線後持續監測

教學重點｜AI 法案也規範「使用者」（部署者）：歐盟醫院要負責人類監督、紀錄保存與告知——不只是廠商的事。

台灣：基本法定原則，衛福部訂醫療規範

法律、行政指導、院內規範要分開看（查證日期： 2026-10-17 ）

2026.01	**人工智慧基本法（法律）** ｜ 2025-12-23 三讀、 2026-01-14 公布施行；國科會主管；七大原則
2026.05	**醫療機構應用生成式 AI 指引（行政指導）** ｜衛福部 2026-05-29 函頒；非強制； AI Agent 暫不納入
2026.08	**AI 醫療相關細則（研擬中）** ｜衛福部 8 月表示將提出草案； 10/17 查證時尚未見公開預告
持續	**TFDA 醫材管理（法律）** ｜醫療器材管理法； AI/ML 醫材軟體查驗登記技術指引

資料來源：人工智慧基本法（2026-01-14 公布）；衛福部 2026-05-29 公告 https://www.mohw.gov.tw/cp-7407-86695-1.html ；中央社（2026-08-06）。

教學重點｜基本法是法律；衛福部指引是行政指導、非強制；醫院要把它轉成自己的院內規範。

Part 3 | 台灣

衛福部《醫療機構應用生成式人工智慧指引》：三階段九項

2026-05-29 衛部醫字第 1151663164 號函頒；行政指導、非強制；涉及醫材者依醫材法規

階段	應注意事項	可轉成的院內做法
導入前評估	風險盤點；法規遵循檢視；資安與資料保護評估	指定主責單位、風險分級；建立安全性說明文件與風險事件紀錄表
導入與整合	系統整合與效能驗證；供應商管理與採購	契約要求揭露模型名稱與版本、資料只用於約定目的；分階段導入，訂擴大與暫緩門檻
導入後監管	持續監測與偏誤管理；風險意識文化；責任分工與教育訓練；資訊透明	監測錯誤類型與手動修改頻率，必要時暫停或回復原流程；告知 AI 參與範圍， AI 對話要揭露；錄音錄影先告知，拒絕即停止

資料來源：衛生福利部醫事司（2026-05-29）醫療機構應用生成式人工智慧指引（附件全文） https://www.mohw.gov.tw/cp-7407-86695-1.html 。查核 2026-10-17 。

教學重點｜上課前先讀附件原文：新聞整理的「五項要求」只是摘要，全文是三階段九項。

Part 3 ｜比較

台灣、美國、歐盟：醫療 AI 監管重點比較

延續 W2 的比較，本週聚焦「上市後」與「使用端」

面向	台灣	美國	歐盟
上市審查	TFDA 三級制	510(k) 、 De Novo 、 PMA	MDR 公告機構＋ AI 法案
模型更新	依變更規定辦理	PCCP 預先核准	依 MDR 變更管理
使用端規範	生成式 AI 指引（非強制）	依各州與機構政策	部署者義務（人類監督等）
透明度	仿單與指引要求	透明度原則、模型資訊揭露	使用說明與紀錄義務
整體架構	基本法＋部會規範	既有醫材法規延伸	AI 專法＋醫材法規

教學重點｜共同趨勢很清楚：從「上市前一次審」走向「上市後持續管」，而且開始要求「使用端」負責。

04

PART 4

倫理、可解釋性與透明度 Ethics, Explainability & Transparency

讓人看得懂、查得到、有人負責

AI 基本法七大原則在醫療的意涵；可解釋性的方法與限制
模型卡： AI 產品的「營養標示」

Part 4 ｜倫理原則

AI 基本法七大原則，放進醫療現場是什麼意思？

原則本身很抽象，要轉成可檢查的做法

永續性與福祉
導入前定義要改善的病人結果

人類自主
流程保留人工判斷與推翻機制

隱私與資料治理
去識別化、存取紀錄、契約限制

資安與安全
弱點管理、停用與備援機制

AI 基本法
七大原則 → 可檢查的做法

透明與可解釋
模型卡、告知病人

公平與不歧視
次族群效能分析（W12）

醫療意涵：以病人福祉為目的、決策最終由人做出、出錯時責任清楚

問責
AI 治理委員會、事件通報

教學重點｜七大原則與 W2 的 WHO 六大倫理原則高度一致——國際共識已經形成，差別在落實的細節。

Part 4 ｜可解釋性

常見的可解釋方法：讓人看見 AI 「看了什麼」

可解釋性（ Explainability ）是 W8 FDA 條件④的核心

方法	怎麼做	醫療例子	限制
特徵重要度	顯示各變數對預測的貢獻（如 SHAP ）	預警畫面列出「呼吸、 SpO_2 、尿量」	相關不等於因果
熱區圖	標示影像中影響判斷的區域（如 Grad-CAM ）	X 光上標出結節位置	熱區可能落在無關處
相似案例	找出訓練資料中相似的病例	顯示 3 個相似皮膚病灶	相似不代表同病
反事實說明	說明哪些數值改變，結果就會不同	「若乳酸 ＜2 ，風險降為中」	可能提出不可行的改變
本質可解釋模型	使用規則或簡單模型	評分表、決策樹	可能犧牲效能

教學重點｜介面上的解釋，是幫醫師「檢查」 AI ，而不是幫 AI 「說服」醫師。

Part 4 ｜限制

可解釋性的「虛假希望」

Ghassemi 、 Oakden-Rayner 、 Beam （ Lancet Digital Health, 2021 ）

問題在哪

- 事後解釋只是「近似」模型的行為，未必忠實
- 熱區看起來合理，人就更容易相信——反而加重自動化偏誤（ W8 ）
- 個別解釋無法證明模型整體可靠

建議的做法

- 整體可信度靠嚴謹驗證（ W12 ），不靠個別解釋
- 解釋用於除錯、稽核與發現偏誤
- 臨床上清楚說明適用範圍與已知失效情境
- 高風險且可行時，優先選本質可解釋模型

教學重點｜可解釋性不是萬靈丹：它是治理工具之一，不能取代外部驗證與上市後監測。

Part 4 ｜告知與同意

什麼時候要告訴病人「這裡用了 AI」？

依「AI 對病人的影響程度」決定告知強度（教學建議）

AI 對病人影響越大，告知越明確

影響：間接

排班、床位、庫存等行政 AI

醫院公告 AI 使用政策即可

影響：中

醫師參考用的 CDS、影像輔助

院內公告＋病人詢問時能說明

影響：中，涉隱私

環境式記錄（錄音）

事先告知並取得同意；可拒絕

影響：直接

AI 直接與病人對話

明確揭露是 AI，提醒勿完全信賴

影響：高

AI 自主判讀、直接影響治療

納入知情同意說明

教學重點｜告知不是免責聲明；重點是讓病人知道「有人負責」，以及他有拒絕或詢問的權利。

模型卡： AI 產品的「營養標示」

Mitchell 等（2019）提出；美國 ONC HTI-1 規則（2023）要求 EHR 揭露預測型決策支援的來源資訊

模型卡 Model Card

模型細節	誰開發、版本、日期、演算法
預期用途	給誰用、什麼情境；不適用情境
訓練與評估資料	來源、期間、族群組成
效能指標	鑑別、校準、閾值表現＋區間
次族群分析	依年齡、性別等分組效能
限制與警語	已知失效情境、倫理考量
維護資訊	更新頻率、監測方式、聯絡窗口

像營養標示一樣
採購前一眼看清：適合誰、不適合誰

出處
Mitchell 等（2019）提出
美國 ONC HTI-1 （2023）： EHR 須揭露預測型 DSI 來源資訊

警訊
「限制：無」——沒有任何 AI 沒有限制（演練二）

教學重點｜W12 的「七份證據」加上模型卡，醫院就能在採購前看清楚：這個 AI 適合誰、不適合誰。

國際案例｜美國・宣稱責任

宣稱「幻覺率 < 十萬分之一」： Pieces 與德州檢察長和解

2024 年 9 月；生成式 AI 病況摘要工具，供多家德州醫院使用；依消費者保護法處理

廠商宣稱

嚴重幻覺率

< 1 / 100,000

→

州檢察長調查

指標「很可能不準確」

以自願遵循保證（AVC）和解，為期 5 年；公司表示不涉及產品安全

和解要求

指標怎麼算

清楚定義與計算方式，或請獨立第三方稽核

不得誇大

不做錯誤、誤導或無法證實的宣稱

給客户文件

已知風險、訓練資料類型、預期用途與限制

教學重點｜即使不是醫療器材，宣稱的數字一樣要負責；和解要求的文件，幾乎就是一張模型卡。

05

PART 5

資料治理與隱私 Data Governance & Privacy

訓練 AI 需要資料；病人有權知道資料怎麼被用

個資法特種個資、 2025 年修法；憲法法庭健保資料案
去識別化光譜、再識別風險；聯邦學習等隱私強化技術

Part 5 ｜個資法

健康資料是「特種個資」：原則禁止，例外允許

《個人資料保護法》第 6 條：病歷、醫療、基因、健康檢查等資料

常見的例外情形（節錄）

- 法律明文規定
- 公務機關執行法定職務或非公務機關履行法定義務所必要，並有適當安全措施
- 公務機關或學術研究機構基於醫療、衛生目的，為統計或學術研究必要，且資料無從識別特定當事人（民間廠商不適用此款）
- 當事人書面同意（有法定限制）

2025 年個資法修正重點

- 2025 年 10 月 17 日立法院三讀
- 設立個人資料保護委員會為獨立監管機關（組織法仍待完成）
- 外洩事件須通報並通知當事人
- 公務機關應設個人資料保護長
- 過渡期間由現行主管機關續管，約 6 年移轉

資料來源：個人資料保護法第 6 條；中央社（2025-10-17）〈立院三讀個資法 公務機關應設個人資料保護長〉。

教學重點｜訓練醫療 AI 最常用的路徑是「學術研究＋去識別化＋倫理審查」——三者缺一不可。

台灣案例｜憲法法庭

健保資料案： 111 年憲判字第 13 號

2022 年 8 月 12 日判決；影響所有以健保資料訓練 AI 的研究與產品

背景 Context

- 健保資料庫長年提供學術研究使用
- 民眾要求停止目的外利用遭拒，提起訴訟並聲請釋憲

做法 Approach

- 判決：目的外利用欠缺足夠法律明確規範，且未提供當事人請求停止利用（退出）的機制
- 要求 3 年內修法補足
- 健保署自 2025 年 8 月 12 日起受理停止目的外利用申請

成果 Results

退出權

民眾可申請健保資料停止目的外利用

審議中

《全民健康保險資料管理條例》草案

獨立機台

去識別化資料僅能在指定場所分析、攜出統計結果

資料來源：憲法法庭 111 年憲判字第 13 號判決；衛生福利部新聞稿（2025-08）。

教學重點｜啟示｜資料可以用，但要有法律依據、要能退出、要有監督——這是台灣醫療 AI 資料治理的新基準。

去識別化是一道光譜，不是開關

越往右越安全，但資料可用性也越低



可直接識別	假名化	去識別化	匿名化	合成資料
姓名、身分證號	以代碼取代身分，保有對照表	移除或概括化可識別欄位	無法以合理方式再識別	由模型生成、不對應真人
仍是個資	仍是個資（可回推）	依情境判斷再識別風險	多數法規不再視為個資	仍需檢查是否「記住」真人

國際作法：美國 HIPAA 提供兩種途徑——「安全港」移除 18 類識別資訊，或由專家判定再識別風險極低。

教學重點｜假名化資料仍是個資：只要醫院手上還有對照表，就要用個資的標準保護。

Part 5 ｜再識別風險

移除姓名，不等於無法辨識

Rocher 等（Nature Communications, 2019）：少數人口屬性就能重新辨識個人

99.98%

美國人可用 15 項人口統計屬性重新辨識

即使資料集已「去識別化」並經抽樣

醫療資料的高風險欄位

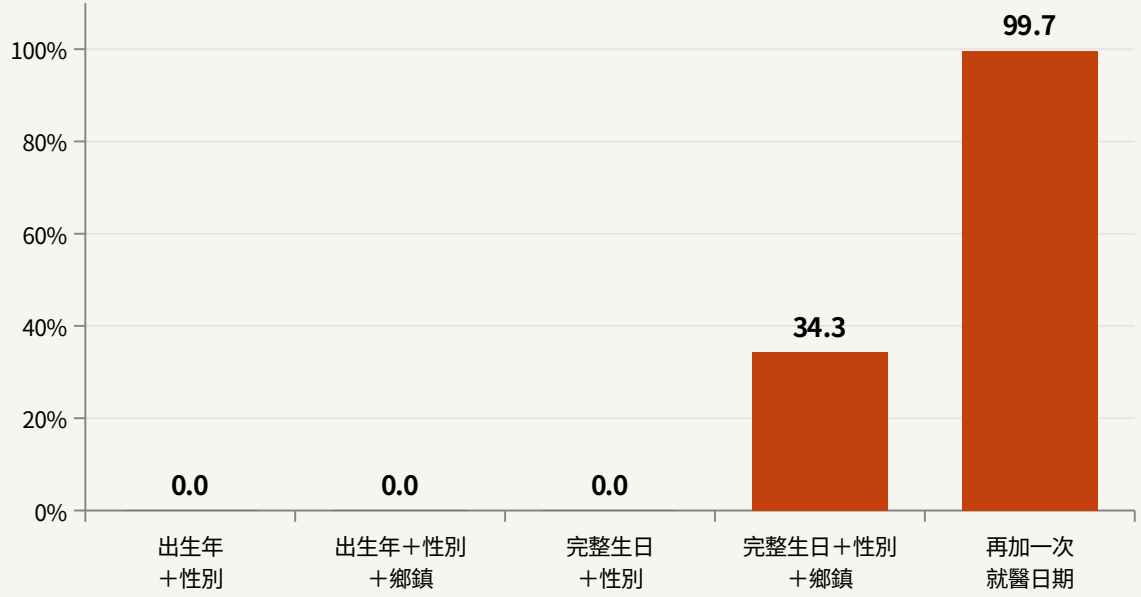
- 出生日期＋性別＋郵遞區號
- 罕見疾病、罕見檢驗結果
- 完整的就醫時間序列
- 臉部影像、頭部 MRI 可重建臉型
- 病歷自由文字中的人名與地點

教學重點｜所以健保資料只開放在獨立機台分析、稀少個案不開放——控制「誰能接觸資料」與「能帶走什麼」同樣重要。

Part 5 ｜實算

保留哪些欄位，就決定多少人會被唯一辨識

以 2,300 萬人計，假設各組合均勻分布（概念示意）：在資料裡「獨一無二」的人占多少?



約 391 人
出生年＋性別＋鄉鎮：平均每組人數

1.1 人
換成完整生日：平均每組只剩約 1 人

99.7%
再加一次就醫日期：獨一無二的比例

出生年改成完整生日，獨一無二的比例就從約 0% 跳到三成多；再加一次就醫日期，幾乎人人可辨識。

不搬資料也能訓練 AI： 隱私強化技術

讓「資料不出院」成為可能

聯邦學習 模型到各院學習，只回傳參數
＋ 資料不出院、可跨院
－ 各院格式需一致（W3）

可信資料空間 受控環境分析，只能帶出結果
＋ 易稽核、符合健保模式
－ 使用不便、需申請

差分隱私 在結果中加入可控雜訊
＋ 可數學證明的隱私保護
－ 雜訊降低準確度

合成資料 生成統計特性相似的假資料
＋ 便於教學、開發、測試
－ 可能失真或洩漏真人

實例： EXAM 研究以聯邦學習串連全球 20 個機構，訓練 COVID-19 病人氧氣需求預測模型（Dayan 等， Nature Medicine 2021）。

教學重點｜台灣次世代數位醫療平台與 FHIR 標準（W3），正是跨院聯邦學習的基礎建設。

國際案例｜美國・資安教訓

Change Healthcare：一次勒索攻擊，影響 1.9 億人

2024 年 2 月遭 BlackCat 勒索軟體攻擊；2025 年 7 月最終通報

入侵
未啟用多因素驗證的舊系統

癱瘓
全美理賠處理與照護服務中斷數月

贖金
承認支付約 2,200 萬美元比特幣

通報
受影響者最終約 1.927 億人

192.7
百萬人
約為初估的兩倍

對醫院 AI 的意義
AI 要集中資料，就要先算好被攻擊時的代價

台灣對應
衛福部指引：導入前資安評估；個資法修法：外洩須通報

教學重點｜資料越集中，被攻擊的代價越大：最小化、存取控管、多因素驗證與聯邦學習都是資料治理。

06

PART 6

國際案例與擬真演練 Case Analysis & Simulation

資料治理出錯的代價，以及三個 AI 產品的判定

英國： DeepMind 與 Royal Free 醫院資料分享案
演練：判定三個 AI 產品是否屬醫材；檢視 HF-Guard 模型卡

國際案例｜英國・教訓

Royal Free 醫院與 DeepMind：好意的應用，違法的資料分享

英國資訊專員辦公室（ICO） 2017 年 7 月裁定

背景 Context

- DeepMind 與 Royal Free 合作開發急性腎損傷警示 App 「Streams」
- 目的是及早發現腎功能惡化——臨床上有價值

做法 Approach

- 醫院將約 160 萬名病人的紀錄提供給 DeepMind 用於測試
- 病人未被充分告知，也無從得知或拒絕
- 依據為「直接照護」，但多數病人並未接受腎臟相關照護

成果 Results

160 萬

被分享資料的病人數

違法

ICO 認定醫院未遵守資料保護法

限期改善

醫院須簽署承諾並委託稽核

資料來源：UK ICO （2017-07-03） Royal Free – Google DeepMind trial failed to comply with data protection law 。

教學重點｜啟示｜目的正當，不代表資料使用正當：告知、必要性與比例原則，一樣都不能少。

擬真演練 Simulation

演練一：三個 AI 產品，哪個是醫療器材?

分組 10 分鐘：用本週的判定流程與 IMDRF 矩陣填表

產品	預期用途與使用者	是否醫材	風險等級（IMDRF）	判斷理由
A 肺結節偵測 AI				
B 病床調度預測				
C 樂齡跌倒 App				

加分題：產品 C 若要「不」被認定為醫材，文案該怎麼寫？反過來，什麼樣的文案一定會讓它成為醫材?

教學重點｜填表時，先寫「預期用途」——答案幾乎都藏在那一欄。

擬真演練 Simulation

演練二：檢視 HF-Guard 模型卡（虛構，延續 W2）

找出至少 4 個「缺漏或令人擔心」之處，並寫出應補充的內容

HF-Guard 心衰竭惡化預警　模型卡 v2.1

預期用途：預測居家心衰竭病人 7 天內惡化風險
訓練資料：某醫學中心 2019–2022 年 3,200 位病人
效能： AUROC 0.86 （內部測試集）
輸入：體重、血壓、心率（指定品牌設備）
更新：模型會依新資料自動持續學習
限制：無
聯絡： service@hfguard.example

檢視提示

- 對照本週模型卡七欄
- 對照 W12 的七份證據
- 想想：王伯伯適用嗎?
- 想想：在台灣上市要補什麼?

教學重點｜「限制：無」本身就是最大的警訊——沒有任何 AI 是沒有限制的。

實務應用 Practice

AI 採購檢核表（完整版）： W12 證據＋ W13 法規與治理

可直接轉成需求說明書或評選須知的審查項目

面向	要求廠商提供	出處
證據	適用範圍、資料來源、外部驗證、完整指標、次族群、本地驗證、上市後監測	W12 七份證據
法規	是否為醫材、 TFDA 許可證字號與等級；非醫材者說明判定理由	W13 Part 1–2
更新	版本管理、更新頻率、變更或 PCCP 計畫、更新前通知	W13 Part 3
透明	模型卡、使用說明、已知限制與失效情境	W13 Part 4
資料	資料存放位置、去識別化方式、不得再利用條款、外洩通報	W13 Part 5
責任	錯誤責任分擔、事件通報窗口、停用與退場機制	W8 、 W15

教學重點｜這張表是 W12–W13 的「帶得走的工具」： 下次參與 AI 採購評選，可直接拿來用。

延伸學習 Further Learning

延伸學習：法規、指引與透明度文件從哪裡查

課後自學用，不列入評量；參與採購評選或撰寫院內規範時可直接查原文

TFDA
醫療器材軟體指引
認定參考指引、 AI/ML 查驗登記技術指引
對應 Part 1–3

衛福部
醫療機構應用生成式 AI 指引
三階段九項全文（2026-05-29）
對應 Part 3

美國 FDA
PCCP 指引
預先核准的修改計畫
對應 Part 3

IMDRF
SaMD 文件
定義與風險分類框架
對應 Part 1–2

EUR-Lex
EU AI Act 全文
高風險 AI 與部署者義務
對應 Part 3

FAccT 2019
Model Cards （Mitchell 等）
模型卡原始論文
對應 Part 4

教學重點｜法規變動快：引用前一律回到官方原文，並寫下查證日期。

名詞小辭典 Glossary

本週名詞小辭典

中英對照，方便閱讀國際文獻

名詞	英文	白話解釋
軟體醫療器材（TFDA 文件稱醫療器材軟體）	Software as a Medical Device, SaMD	本身即具醫療用途、不屬於硬體一部分的軟體
預期用途	Intended Use	產品宣稱的用途、使用者與情境，是判定醫材的核心
預定變更控制計畫	Predetermined Change Control Plan, PCCP	上市前先審查未來的模型修改方式
良好機器學習實務	Good Machine Learning Practice, GMLP	AI 醫材開發的十項指導原則
全產品生命週期	Total Product Lifecycle, TPLC	從設計、上市到更新退場的整體管理
模型卡	Model Card	揭露模型用途、資料、效能與限制的標準文件
假名化	Pseudonymisation	以代碼取代身分；保有對照表，仍屬個資
聯邦學習	Federated Learning	資料不離開機構，只交換模型參數的協作訓練

案例研討 Case Study ｜美國

23andMe： 基因資料外洩之後，公司破產了

撞庫攻擊經「 DNA 親屬」功能放大； 2025 年申請破產並出售

- **2023-04 起** 攻擊者用其他網站外洩的帳密「撞庫」，持續約五個月
- **2023-10** 資料在網路上被兜售，公司確認外洩
- **2025-03-23** 申請美國破產保護，數百萬人的基因資料成為待售「資產」
- **2025-07** 法院核准以 3.05 億美元售予前執行長主導的非營利機構 TTAM

決策點 Decision Point

你是主管機關：公司破產時，基因資料可以跟著公司一起賣嗎？要附什麼條件？

先獨立想 1 分鐘，寫下你的選擇與理由，再看下一頁。

基因資料不能更換；一人的帳號，也連帶洩漏親屬的資料。

結果： 1.4 萬個帳號，洩漏了 690 萬人

撞庫攻擊經「DNA 親屬」功能放大； 2025 年申請破產並出售

約 1.4 萬
被直接入侵的帳號（＜0.1%）

約 690 萬
受影響總人數（經 DNA 親屬等功能）

£231 萬
英國 ICO 罰鍰

監管機關指出的缺口

- 未強制雙因素驗證
- 登入後可直接下載原始 DNA 資料，無額外驗證
- 異常活動未被及時偵測

治理上的難題

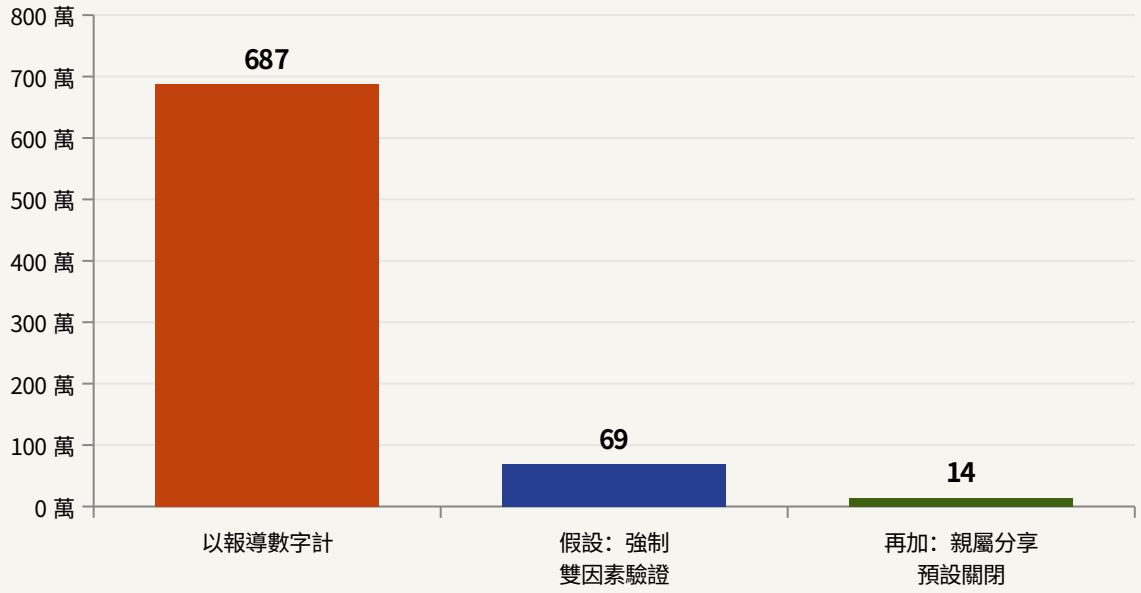
- 分享功能讓一人帳號洩漏他人資料
- 基因資料外洩是永久的
- 破產出售時，原本的同意範圍如何延續?

去識別化與同意之外，還要問：資料的「主人」換了，原本的承諾還算數嗎?

案例研討｜實算

每個帳號牽連近 500 人：兩項對策能擋下多少

撞庫入侵約 1.4 萬個帳號，經 DNA 親屬功能影響約 690 萬人；對策效果為教學假設



約 1.4 萬
直接被入侵的帳號（報導）

約 690 萬
受影響總人數（報導）

約 491 倍
每個帳號平均牽連人數

驗證強度與分享預設值，決定的不只是一個帳號，而是背後整個家族的資料。

案例研討｜課堂討論

討論：把本週的框架用在這個案例

三題擇一深入；先寫判斷，再寫證據與限制

Q1 用台灣個資法：基因資料屬於哪一類？類似事件在台灣會觸及哪些義務？
連結本週：特種個資

Q2 1.4 萬帳號洩漏 690 萬人：這是哪一種連帶或再識別風險？
連結本週：再識別風險

Q3 醫院委外基因檢測，合約要寫進哪些破產、併購時的資料條款？
連結本週：資料治理

課堂進行約 15 分鐘

① 個人閱讀與作答　3 分鐘
② 小組討論，選一題深入　8 分鐘
③ 兩組分享、教師回饋　4 分鐘

出處

Security.org 事件整理； MobiHealthNews 2025-06-16； UK ICO 2025
完整連結見講者備註

沒有標準答案：好答案會說清楚判斷、依據的證據，以及還缺什麼。

Summary

本週重點回顧

一頁掌握醫療 AI 法規、倫理與資料治理

主題	一句話重點
SaMD 判定	看預期用途與宣稱，不看技術；同技術不同文案，身分不同
風險分級	IMDRF 情境 × 資訊重要性；台灣三級、歐盟 Rule 11 較嚴
各國監管	全生命週期： FDA PCCP 、歐盟部署者義務、台灣基本法＋衛福部指引
可解釋性	用來檢查與稽核，不能取代驗證；小心加重自動化偏誤
模型卡	用途、資料、效能、次族群、限制、維護——「限制：無」是警訊
資料治理	特種個資、憲判 13 號退出權；假名化仍是個資；聯邦學習讓資料不出院

教學重點｜帶走一個問題：如果你的醫院要用病歷訓練 AI ，第一個要找的是誰？資訊室、 IRB ，還是法務?

課堂討論 In-class Discussion

課堂討論：回到開場的家屬來信

「我爸的病歷，是不是被你們拿去訓練 AI 了？我能拒絕嗎？」分組 15 分鐘

- **Q1　事實：**你的醫院若真的用病歷訓練 AI，通常需要經過哪些程序？
- **Q2　回覆：**以醫院立場，寫一段 100 字內、家屬看得懂的回覆。
- **Q3　權利：**家屬能拒絕嗎？院內研究資料與健保資料的情況有什麼不同？
- **Q4　制度：**若要讓病人「事先知道、可以選擇」，醫院可以設計什麼機制？

教學重點｜好的回覆要誠實、具體、不推諉——資料治理的信任，往往就建立在這樣一封回信上。

下週預告 Next Week

W14　★ 數位健康經濟評估與導入策略

實作週：講授約 20 分鐘＋課堂實作約 80 分鐘

- AI 值不值得買？ ROI 、成本效果分析與預算衝擊
- 健康科技評估（ HTA ）與健保給付路徑；台灣首件 AI 相關健保給付
- NASSS 框架：為什麼好的科技常常推不動?
- ★ 實作四：用 Vibe Coding 做一個智慧醫療導入 ROI 試算工具（也可用試算表或紙筆完成）

課前準備

- 帶筆電，確認能使用生成式 AI 工具
- 想一個你單位想導入的智慧醫療方案
- 估計它的主要成本與效益項目

教學重點｜下週把 W12 的證據、 W13 的法規，再加上「錢」——就能完整評估一個 AI 方案該不該導入。

主要參考資料

法規以官方最新公告為準（查證日期： 2026 年 10 月）

IMDRF SaMD Working Group (2014). Software as a Medical Device: Possible Framework for Risk Categorization and Corresponding Considerations (N12).

衛生福利部食品藥物管理署（ 2020 ）。人工智慧／機器學習技術之醫療器材軟體查驗登記技術指引；醫療器材軟體認定參考指引。

U.S. FDA (2025-08; first issued 2024-12). Marketing Submission Recommendations for a Predetermined Change Control Plan for AI-Enabled Device Software Functions. Final guidance.

U.S. FDA (2025-01). AI-Enabled Device Software Functions: Lifecycle Management and Marketing Submission Recommendations (Draft Guidance).

FDA, Health Canada, MHRA (2021). Good Machine Learning Practice for Medical Device Development: Guiding Principles.

Regulation (EU) 2024/1689 (AI Act)； Regulation (EU) 2017/745 (MDR) Annex VIII Rule 11 。

人工智慧基本法（ 2026-01-14 公布施行）；個人資料保護法（ 2025 年修正）；憲法法庭 111 年憲判字第 13 號判決。

Mitchell M, et al. (2019). Model cards for model reporting. FAT* '19.

Ghassemi M, Oakden-Rayner L, Beam AL. (2021). The false hope of current approaches to explainable AI in health care. Lancet Digital Health, 3(11), e745–e750.

參考資料 References

案例與新聞出處

本週案例之原始來源；數據以原始文獻為準

UK Information Commissioner's Office (2017-07-03). Royal Free – Google DeepMind trial failed to comply with data protection law.

Rocher L, Hendrickx JM, de Montjoye YA. (2019). Estimating the success of re-identifications in incomplete datasets using generative models. Nature Communications, 10, 3069.

Dayan I, et al. (2021). Federated learning for predicting clinical outcomes in patients with COVID-19. Nature Medicine, 27, 1735–1743.

衛生福利部（2026-05-29）。醫療機構應用生成式人工智慧指引（衛部醫字第 1151663164 號函頒）。

中央社（2026-08-06）。厚生會成立智慧醫療委員會 衛福部擬提 AI 醫療細則草案。

中央社（2025-10-17）。立院三讀個資法 公務機關應設個人資料保護長。

衛生福利部（2025-08）。健保資料停止目的外利用申請相關新聞稿。

蕃新聞（2026-06-30）。 42 萬人受惠醫材落地 智慧醫療 2026 新趨勢（食藥署智慧醫材專案辦公室）。

Texas Office of the Attorney General (2024-09). Assurance of Voluntary Compliance with Pieces Technologies （Nelson Mullins 2024-09-20 整理）.

Healthcare IT News (2025-08-06). New numbers: Change Healthcare data breach 193 million affected.

CLOSING

規範不是煞車，是方向盤

清楚的預期用途、透明的模型卡、受尊重的病人資料——讓醫療 AI 走得快，也走得遠。